

10 Real SOC Analyst Interview Questions

With the answer frameworks interviewers expect - from CyberVerse AI (app.grcwithgaurav.com)

1. A domain controller is making outbound connections to an external IP on port 443. How do you investigate?

- Validate source host, process, user context via EDR
- Enrich destination IP with threat intel and DNS logs
- Scope: other hosts, odd logons, new services
- Contain, preserve evidence, eradicate, document

2. A user clicked a phishing link. Walk me through your response.

- Isolate the host
- Collect URL, headers, downloads
- Check proxy/DNS logs for exfiltration
- Reset creds, scan for persistence, document

3. How do you detect multiple failed logins followed by a success in Splunk?

- stats count of 4625 by account + source IP in a window
- Threshold filter
- Correlate a 4624 success for the same account
- Prefer stats over transaction at scale

4. True positive vs false positive - how do you decide?

- Reproduce evidence from raw logs
- Compare to known-good baseline
- Enrich with threat intel and asset context
- Escalate with confidence level when unsure

5. Walk me through an ISO 27001 risk assessment.

- Scope + asset inventory
- Threats/vulnerabilities per asset
- Likelihood x impact scoring
- Treatment plan mapped to the SoA

6. What is a Statement of Applicability?

- List of all Annex A controls (93 in 2022)
- Applicable/excluded with justification
- Risk-owner sign-off, versioned

7. How do you assess third-party vendor risk?

- Tier by data access and criticality
- Evidence: SOC 2, ISO certs, pen tests
- Contract clauses: breach notification, audit rights
- Continuous monitoring cadence

8. A zero-day with public exploit code drops. How do you prioritize?

- Confirm affected assets in inventory
- Judge exposure and exploitability
- Virtual patch / WAF now, patch by exposure order
- Hunt for pre-patch compromise

9. How would you detect a Kerberos Golden Ticket attack?

- 4769 anomalies: odd lifetimes, missing PAC
- TGT renewals without matching 4628/4768
- Privileged logon anomalies
- Monitor KRBTGT resets

10. How do you reduce alert fatigue in a SOC?

- Measure FP rate per rule
- Kill/tune noisy rules
- Enrich alerts to be actionable
- Monthly detection review with owners

Want to practice these out loud with an AI interviewer that scores you out of 100? Visit app.grcwithgaurav.com - free.